OWASP Top 10 2025: Insecure Data Handling

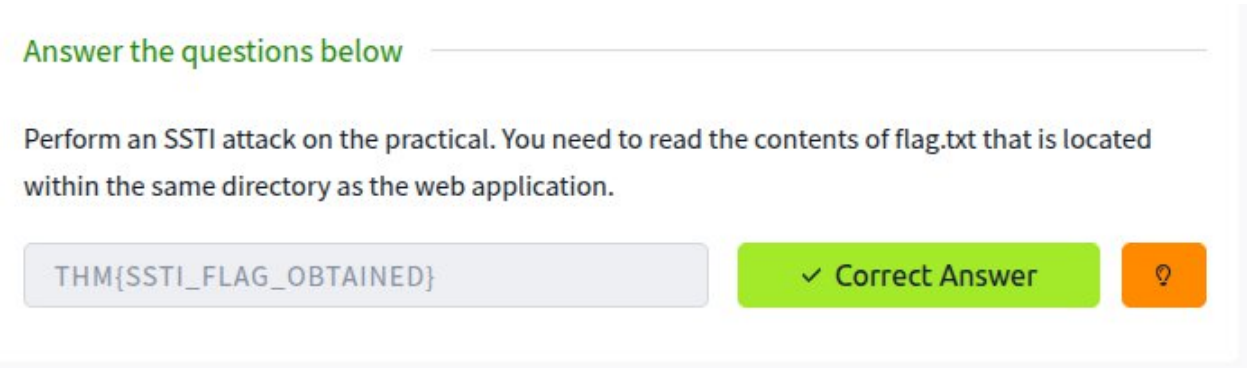
A04: Cryptographic Failures

Cryptographic failures occur when applications do not properly protect sensitive data through encryption or secure handling practices. This can happen either because encryption is not used at all, or because it is implemented incorrectly. As a result, attackers may be able to read or manipulate data that should have been kept confidential.

Common causes include:

- Storing sensitive information such as passwords in plain text instead of hashing them
- Using weak or outdated hashing algorithms like MD5 or SHA-1, which are vulnerable to cracking
- Transmitting data over insecure channels (HTTP instead of HTTPS), allowing interception through man-in-the-middle attacks
- Poor key management, such as hardcoding encryption keys or reusing them across systems

Impact:
When cryptographic protections fail, attackers can gain access to highly sensitive information. This may include user credentials, financial details, or personal data. Such exposure can lead to data breaches, account takeovers, identity theft, and loss of user privacy. In many cases, it can also result in legal and compliance issues for organizations.



A05: Injection

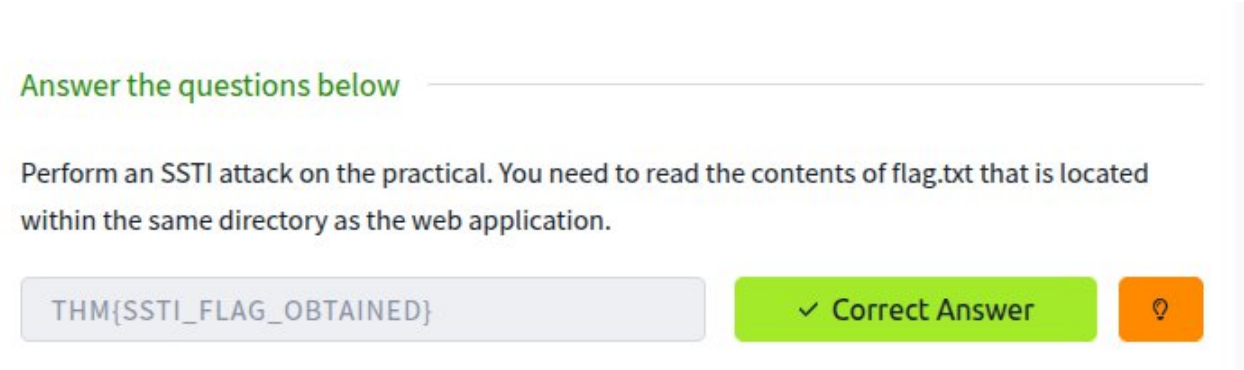
Injection vulnerabilities occur when an application accepts user input and fails to handle it safely. Instead of treating input as data, the application directly includes it in commands or queries executed by systems such as databases, operating systems, APIs, or template engines. This allows attackers to manipulate the intended behavior of the application.

How it works:
When user input is directly concatenated into a query or command without validation or sanitisation, an attacker can insert malicious payloads. For example, in SQL Injection, input fields like login forms are exploited by injecting SQL statements that alter the database query logic. This can allow attackers to bypass authentication or retrieve sensitive data.

Common types of injection:

- **SQL Injection:** Manipulating database queries to access or modify data
- **Command Injection:** Executing arbitrary system commands on the server
- **Server-Side Template Injection (SSTI):** Injecting code into template engines to execute server-side logic
- **AI Prompt Injection:** Manipulating AI model inputs to alter outputs or extract sensitive information

Impact:
Injection attacks can lead to severe consequences, including unauthorized data access, data modification, remote code execution, and full system compromise. In many cases, attackers can gain administrative control over the application or underlying server.



A08: Software or Data Integrity Failures

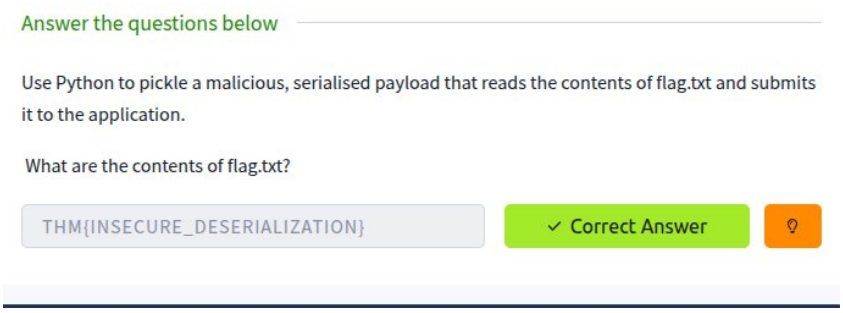
Software or Data Integrity Failures occur when an application trusts code, updates, or data without verifying whether they are authentic and unaltered. Instead of validating the source and integrity, the application assumes that everything it loads or executes is safe. This creates opportunities for attackers to introduce malicious code or manipulate data that directly affects application behavior.

How it works:

These failures typically happen when applications accept external inputs such as libraries, configuration files, templates, or serialized data without proper verification. For example, if a system loads a software update without checking its checksum or signature, an attacker could replace it with a malicious version. Similarly, insecure deserialization allows attackers to send crafted data that, when processed, executes unintended or harmful operations on the server.

Common scenarios:

- Installing or updating software from untrusted or unverified sources
- Loading third-party libraries or dependencies that have been tampered with
- Accepting serialized objects (e.g., JSON, Python objects) without validation
- Weak or missing integrity checks in CI/CD pipelines

Impact:

Exploiting these vulnerabilities can lead to severe consequences such as remote code execution, system compromise, unauthorized access, and supply chain attacks. Attackers may gain control over application logic or distribute malicious updates to multiple users.